

THE FORENSICS WAY

ISSUE 36

FORENSICS AWARENESS THIS WEEK

TUESDAY, OCTOBER 6, 2026

FRONT PAGE

ZERO-DAY

Patched But Still Occupied: Two NetScaler Zero-Days Surfaced by Forensic Work Make the Patch the Least Important Step

Citrix published bulletin CTX697096 on September 27 for two NetScaler ADC and Gateway zero-days, both rated CVSS 9.5. CVE-2026-88771 is an unauthenticated remote code execution flaw affecting all deployments; CVE-2026-88772 is a memory overflow reachable where DTLS is enabled. Neither was found by a scanner. watchTower warned clients of their exposure on September 26 — before CVE IDs existed — because the flaws surfaced during forensic investigations of appliances that had already been compromised.

Unit 42's reconstruction puts fingerprinting from two hosts as early as August 21, with an actor repeatedly pulling files from the appliance's `/vpn/scripts/linux/` directory between September 4 and 24; exploitation escalated into mass attacks by September 29. The payload of choice was a web shell, which is the detail that matters: a web shell planted before the fix existed is unaffected by applying the fix. Forensic priority: treat patching and eviction as two separate tasks. Inventory the filesystem for files written during the exposure window rather than trusting a version check, and follow Citrix's own guidance to reset credentials and revoke certificates on the assumption the appliance's secrets were readable.

CREDENTIAL EXPOSURE

Deleted Is Not Revoked: 543,699 Still-Working Credentials Found Inside an AI Training Corpus, Median Age 784 Days

Truffle Security published research on September 29 built on The Stack v3, a machine-learning training corpus of 224.5 million public repositories and some 58.5 billion file entries captured through August 2025. Re-verifying candidate secrets against their issuing providers on July 27–28, 2026, the team found 543,699 unique credentials that still authenticated. The median had been public for 784 days; the oldest dated to 2009 and worked after sixteen years.

THREAT BULLETIN

Active Exploit

CVE-2026-76504 — Cisco Catalyst SD-WAN Manager. Inconsistent handling of URI hex encoding (CWE-177) lets a crafted HTTP request slip past the authentication rule guarding an API endpoint, yielding unauthenticated admin-level access. CVSS 9.8; added to CISA KEV September 30 with an October 3 federal deadline. *Forensic Note:* Cisco's indicators centre on a URI-encoded "j" inside the `j_security_check` login-handler path — hunt that pattern in raw web logs, since normalised logs may hide it.

Active Exploit

CVE-2026-102489 / CVE-2026-102490 — Zammad. A session-fixation flaw paired with an improper privilege-management flaw in the open-source help-desk platform, both added to CISA KEV on October 2. Session fixation lets an attacker pre-set a session identifier and then inherit the victim's authentication. *Forensic Note:* Session fixation leaves no failed-login trail, so audit session identifiers that predate their own successful authentication and review privilege changes on agent accounts.

Roughly 200,000 of them were pushed after GitHub enabled default push protection in February 2024, and 51.8 percent of all live credentials matched patterns the default configuration does not block. The sharpest finding is that blocking is not what saves you: push protection cut credential density by about half, but survival tracked provider behaviour — issuers with a kill switch showed near-total revocation, while database connection strings survived at 75–88 percent. Forensic priority: a training corpus is a copy you cannot recall, so scrubbing a repository does not scrub the dataset built from it. Scope credential exposure from the issuer's own issue-and-revoke records, not from current repository contents.

SC — The WordPress Backdoor That Rebuilds Itself From Any Survivor

Sucuri documented a WordPress compromise it calls a "self-healing mesh," named SC after the `SC_` markers in the injected content. Researcher Gabriel Barbosa describes a payload living in at least eight places at once — a `.user.ini` using `auto_prepend_file`, hidden PHP loaders, theme files, a must-use plugin, a database options row, a System V shared-memory segment and randomly named ZIP bundles — each able to rebuild all the others. *Forensic Note:* One surviving copy restores everything on the next page load, so enumerate all eight classes before removing any; shared memory and the database will not appear in a file-integrity scan.

THE FORENSICS WAY

HISTORICAL ARCHIVES

HISTORY OF DIGITAL INVESTIGATION

TUESDAY, OCTOBER 6, 2026

CASE STUDIES: HISTORICAL GRID

JUNIPER SCREENOS (2015)

Unauthorized Code in the Firewall: When the Appliance Itself Was the Thing That Could Not Be Trusted

On December 17–18, 2015, Juniper disclosed that an internal source-code review had turned up

THE UBER BREACH AND COVER-UP (2016)

The Keys Were in the Repository: A Credential Leak That Became a Criminal Case About the Response

In October 2016, attackers reached a private GitHub repository used by Uber engineers, lifted

unauthorized code in ScreenOS, the operating system behind its NetScreen firewalls. The advisory covered two separate backdoors: a hardcoded master password granting administrative access over SSH and Telnet (CVE-2015-7755), and an altered Q parameter in the Dual_EC_DRBG random number generator that let a passive eavesdropper decrypt VPN traffic (CVE-2015-7756). The earliest affected builds shipped in 2012, leaving the code in production for roughly three years, and Fox-IT recovered the backdoor password within six hours of disclosure. It is the clearest precedent for this week's NetScaler story — both turn on the uncomfortable fact that a security appliance's own firmware is evidence to be verified, not assumed.

AWS credentials committed into it, and used them to pull an S3 datastore holding records on roughly 57 million riders and drivers, including some 600,000 driver's licence numbers. Uber paid the attackers \$100,000 routed through its bug-bounty programme and obtained non-disclosure agreements, and the breach stayed unreported until November 2017; the company's security chief was convicted of obstruction of justice and misprision of a felony in October 2022. It is the canonical version of the pattern in this week's credential research — a secret committed to a repository outlives the commit — and a reminder that incident-response records are themselves discoverable evidence.

OPERATION CLOUD HOPPER (2017)

One Door, Every Building: The Campaign That Made Managed Service Providers the Highest-Value Target in the Chain

Disclosed in April 2017 by PwC and BAE Systems, Operation Cloud Hopper documented how APT10 compromised managed service providers and then used the legitimate, trusted connections those providers held into client networks to reach an unprecedented breadth of victims across a dozen countries. Investigators faced a defining difficulty: from a client's perspective, the attacker's traffic arrived over exactly the channel their IT provider was supposed to use, at exactly the times support work normally happened. The case established that compromising the layer everyone trusts beats compromising anyone individually.

THE FAKE RESEARCHER CAMPAIGN (2021)

Targeting the People Who Hunt: When Attackers Built a Research Community to Reach Its Members

In January 2021, Google's Threat Analysis Group exposed a North Korea-linked operation that spent months constructing a credible security-research presence — a research blog, guest posts, social media personas with genuine follower networks — for the sole purpose of approaching working vulnerability researchers and inviting them to collaborate on projects that carried a hidden payload. Several targets were compromised despite being precisely the audience most equipped to spot a malicious file, because the lure did not arrive as a file from a stranger; it arrived as a professional opportunity from a peer.

TOOLS OF THE TRADE

OPEN SOURCE

Artemis

PUFFYCID — V0.20.X

Cross-platform forensic parser written in Rust, collecting from Windows,

OPEN SOURCE

radare2

V2.5.X — REVERSE
ENGINEERING

Reverse-engineering framework for

COMMERCIAL

OSForensics

PASSMARK — V11.1

Windows investigation suite combining disk imaging, file carving, full-

UTILITY / SCRIPT

DFIR Companion

V0.41.X

Post-processing companion that turns collected evidence into

macOS, Linux and FreeBSD with collections defined in plain TOML and output to JSON, JSONL or CSV. Its low resource footprint suits triaging the Linux platform under a compromised appliance, where installing an agent is not an option.

disassembly, binary diffing and patching across a wide span of architectures and file formats. Use it to characterise loaders and dropped binaries recovered from an appliance filesystem, and to diff a suspect module against a known-good vendor build.

text indexing, and registry and memory examination in a single case workflow. Its indexed search is the practical way to sweep a large acquired image for committed secrets and credential patterns after a repository-sourced exposure.

analyst-ready output — forensic timelines, IOC blocklists and written findings. Pair it with a live collector to move from a raw artifact dump to a dated timeline of what was written to a host during a known exposure window.

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-94127 (F5 BIG-IP APM)

Heap-based buffer overflow in Access Policy Manager, the component brokering remote access and SSO for the environments behind it; added to CISA KEV September 22. *Forensic Note:* Review APM session logs for malformed requests and unexplained restarts, and re-authenticate every session brokered during the window.

ARCHIVE ALERT

CVE-2026-85102 / CVE-2026-93616

(CHECK POINT)

Improper certificate validation alongside a path-traversal flaw across multiple products, both added to CISA KEV September 22. *Forensic Note:* Audit gateway logs for connections accepted with mismatched certificates, and for file access outside expected directories.

RECENT MALWARE WATCH

ARCHIVE: SEPTEMBER 29, 2026

KREMLIN — BANKING THEFT FROM INSIDE THE BROWSER

Brazilian toolkit chaining JavaScript loaders and C++ installers to plant malicious Chrome and Edge extensions, harvesting session tokens from an already-authenticated browser and so bypassing MFA. Inventory extensions against an approved list and check install timestamps.

ARCHIVE: SEPTEMBER 22, 2026

GRAYRABBIT — THE BACKDOOR RIDING AN INPUT METHOD'S CHROMIUM FLAW

Modular backdoor linked to UNC3569, delivering a reverse shell plus plugin loading, file upload and system reconnaissance through a keyboard utility. Hunt reverse-shell connections originating from IME-related processes.